ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

ABB ACS580 / ACH580 / ACQ580 Variable Frequency Drive (all-compatible drive platform) · Component type: **Embedded Device (EDR) - variable frequency drive (VFD)** · Target SL = SL 3

Where to work	Native config at the **Assistant control panel** (ACS-AP-I / ACS-AP-W Bluetooth / ACS-AP-S) and in **Drive Composer Entry/Pro** (PC tool over panel **USB** or Ethernet). The key security control is the **USER LOCK, parameter group 96**: enter default pass code **10000000** in **96.02**, change it via **96.100/96.101**, and in **96.102 (user lock functionality)** select the actions to PREVENT (panel/PC parameter changes, firmware/file download, **USB**, panel **Bluetooth**). Comms: embedded fieldbus (**EFB Modbus RTU** on RS-485) + a plug-in **fieldbus adapter** (FENA-21 / FEIP-21 / FMBT-21 / FPNO-21 / FSCA-01), some with a **web UI**. Safety: built-in **STO**, optional **FSO-12/FSO-21**.
Ports / paths	**EFB Modbus RTU** on the RS-485 terminals; **fieldbus adapter**: Modbus TCP **502**, EtherNet/IP **TCP 44818 / UDP 2222**, PROFINET; **FENA/FEIP web UI HTTP 80** (no HTTPS); panel **USB** (Drive Composer); **Bluetooth** (ACS-AP-W / Drivetune app); **STO** hardwired + **FSO** safety bus (PROFIsafe / CIP Safety). No TLS on the drive/fieldbus (unauthenticated cleartext). Drive type: ACS580 / ACH580 / ACQ580.
Notes / CVEs	ABB ACS580 (general purpose) / ACH580 (HVAC) / ACQ580 (water) - same platform. Distinctive control = the **USER LOCK (group 96)**; change the default pass code **10000000** and record it securely (**ABB cannot recover it** once changed). Patch **Drive Composer** (CISA **ICSA-25-037-03**) and the drive firmware; follow the ABB "Cybersecurity for ABB drives" guide + Technical Note 066. Confirm drive type, firmware, fieldbus-adapter type/firmware, and any FSO safety module.
How to read	Default read-only (panel/Drive Composer parameter review; read-only Modbus/fieldbus reads; fault-log review). Each row = native step-by-step (group-96 params, Drive Composer, adapter web) + command-level external-tool validation + pass. Write/exploit tools = isolated bench + written authorization (a mis-set drive can start a motor / disable safe stop). STO/FSO gets safety scrutiny.

Project / config capture & evidence handling - capture the device backup + config export

Do this BEFORE working the checklist - screenshots and walking the config screens are not enough on their own. Capture the device's own backup / project export so nothing is missed:
1. Pull the native backup / project + full config export first (read-only, before anything): the **ABB Drive Composer** parameter backup (or the assistant control-panel **Backup to panel** copy), the full parameter export incl. **User Lock group 96** (96.02) state, the FENA/FEIP fieldbus-adapter + STO/FSO settings, firmware rev, and the drive fault/event log.
2. Export the security-relevant settings: user accounts / roles / password policy, comms / port / protocol enable-disable, and any certificate / key / CIP-Security settings - as files and screenshots.
3. Collect firmware & logs: firmware / boot revision, and the event / audit / diagnostic logs and fault / alarm buffers (exports) where the device provides them.
4. Capture the device identity: nameplate (catalog + serial), firmware / hardware rev, installed modules / option cards, and slot / network address - **photograph** the device, faceplate / HIM and panel labels.
5. Name + protect (keep everything): `<site>_<zone>_<assetTag>_<vendor>_<model>_<fwRev>_<YYYYMMDD-HHMM>_<initials>` with the native project / backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup may hold credentials / keys - **never** email it in cleartext and follow the project retention / classification policy. Do not save device passwords in tool profiles.
6. Then analyze offsite against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can't auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 1.1	Human user identification & auth	The drive has no multi-user accounts; access control is the **user lock + parameter lock**. Activate the user lock: enter default **96.02 = 10000000**, change it via **96.100/96.101**, then in **96.102** select the actions to prevent so parameter changes via the panel and **Drive Composer** require the pass code. The fieldbus (Modbus/EtherNet-IP) has **no authentication** - compensate with segmentation + the master. **Test:** with the user lock active, attempt a parameter change at the panel / in Drive Composer -> blocked without the pass code. **Ext. tools:** Panel/Drive Composer (group 96 review); attempt a param write w/o pass code -> denied; confirm host restricts who runs Drive Composer.	User lock active + pass code changed; panel/PC config gated; unauthenticated fieldbus compensated by segmentation.	EDR - user lock is the control.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 1.2	Device & software-process I&A	The fieldbus is **unauthenticated**; the drive is identified by its **Modbus station address** (EFB) / fieldbus node / **FENA IP**. Bind identity by a single known master + segmentation; document the address and the authorized master. **Test:** from a non-authorized master, poll the drive -> blocked by segmentation. **Ext. tools:** `modpoll -m rtu -a -b -1 /dev/ttyUSB0` or `modpoll -m tcp -a` (read-only); `nmap --script enip-info -p 44818 .`	Drive identified by station address/IP; single authorized master; unauthenticated protocol compensated.	No fieldbus auth - Compensating.
SR/CR 1.3	Account management	No user accounts; manage the **user-lock pass code** as a controlled secret, the Drive Composer host access, and the **FENA/FEIP adapter web credentials** (change any default). Keep custody of the parameter backup. **Ext. tools:** Pass-code custody record; Drive Composer host review; FENA web (change default creds); backup custody.	Pass code + host + adapter credentials controlled; defaults changed; backup protected.	
SR/CR 1.4	Identifier management	Confirm a unique **Modbus station address** / fieldbus node / FENA IP and a unique drive identity (type + serial); no reuse across the cell. **Ext. tools:** Panel/Drive Composer (address/serial); `modpoll` scan for address collisions; asset register.	Unique drive address/identity; no reuse.	
SR/CR 1.5	Authenticator management	Change the user-lock pass code from the default **10000000** to a strong value (96.100/96.101) and **store it securely - ABB cannot recover it**; set a strong FENA web password; enforce host/AD policy for Drive Composer. **Ext. tools:** Panel (96.100/96.101 changed from default); FENA web (password); host/AD policy; secure pass-code escrow.	Strong user-lock pass code (non-default, escrowed) + FENA/host credentials; managed lifecycle.	
SR 1.6	Wireless access management	If the **ACS-AP-W Bluetooth** panel (Drivetune app) is fitted and not required, **disable Bluetooth** via the user lock (**96.102**) / panel settings; if used, secure pairing and limit range. **Ext. tools:** Panel (Bluetooth enable/disable via 96.102); Bluetooth scan to confirm off when disabled.	Panel Bluetooth disabled if unused (via user lock); secured if used.	Bluetooth panel option.
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	Public key infrastructure (PKI) certificates	**N/A / limited at device.** The drive/fieldbus have no TLS/PKI (FENA web is HTTP; Modbus/EtherNet-IP unauthenticated). Record N/A; provide confidentiality/integrity by segmentation. **Ext. tools:** Confirm no device certificate/TLS; Wireshark (FENA HTTP + fieldbus cleartext).	N/A/limited device PKI; compensating segmentation.	N/A/Partial.
SR/CR 1.9	Strength of public key-based authentication	Confirm public-key authentication uses strong, current keys/algorithms. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of public key-based authentication verified individually.	
SR/CR 1.10	Authenticator feedback	Confirm the pass-code entry is masked at the panel and in Drive Composer (no cleartext echo). **Ext. tools:** Visual verification (panel / Drive Composer).	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	The user lock has **limited/no lockout counter** and the fieldbus does not lock out - compensate with physical control + segmentation + monitoring of anomalous parameter writes at the master/IDS. **Ext. tools:** Physical control; Modbus/OT IDS on the cell for anomalous writes.	No native lockout; physical + segmentation + monitoring compensate.	Legacy limitation.
SR/CR 1.12	System use notification	No banner on the drive/panel; apply an approved-use placard on the drive/cabinet and enforce the notice on the Drive Composer host (GPO). **Ext. tools:** Physical placard; host `gpresult /h gp.html`.	Use notice via placard + host (compensating at drive).	Compensating.
SR 1.13	Access via untrusted networks	Segment the drive into a motor-control cell; firewall the **FENA** Ethernet (502/44818/2222/80) and keep the EFB RS-485 local; no fieldbus from untrusted networks; remote Drive Composer via VPN/jump host; disable the FENA web off-segment. **Test:** from an untrusted VLAN, reach the FENA 502/44818/80 -> must fail. **Ext. tools:** `nmap -Pn -p 502,44818,2222,80` from the untrusted side (expect filtered); firewall review.	Drive/FENA unreachable from untrusted networks; remote via VPN; web off-segment.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 2.1	Authorization enforcement	Authorization = the **user lock 96.102** (which actions are prevented) plus the **control location** (Local/Remote / EXT1-EXT2, groups 19/20) that governs which source may start/stop and set the reference. Confirm a fieldbus master can only do what the control-location config allows and that config changes need the pass code. **Test:** with the user lock on, attempt a param/config change -> denied; confirm a non-selected control source cannot command run. **Ext. tools:** Panel/Drive Composer (96.102 + control-location review); negative test (isolated).	Least privilege via user lock + control-location; unauthorized config/command denied.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR 2.3	Use control for portable/mobile devices	Control the Drive Composer laptop, the panel **USB**, and the **ACS-AP-W Bluetooth**; only authorized firmware/parameter backups loaded; the user lock can disable USB/Bluetooth. **Ext. tools:** Host removable-media GPO; confirm USB/Bluetooth disabled via 96.102 if unused; backup provenance.	Engineering media + USB/Bluetooth controlled; only authorized artifacts loaded.	
SR/EDR 2.4	Mobile code	No general-purpose mobile code; confirm only ABB firmware and the reviewed **adaptive program** (ACS580 adaptive programming) run; no untrusted logic; block firmware/file download via the user lock when not maintaining. **Ext. tools:** Drive Composer (adaptive-program review); user lock (file/firmware download prevented).	Only trusted firmware + reviewed adaptive program; no untrusted code.	EDR-specific.
SR/CR 2.5	Session lock	Confirm the panel reverts/locks on inactivity (re-entry of the pass code required for changes) and the Drive Composer host OS locks on inactivity. **Ext. tools:** Panel inactivity behavior; host inactivity-lock GPO.	Panel/host lock on inactivity; re-auth required.	Compensating (host).
SR/CR 2.6	Remote session termination	Confirm a Drive Composer session can be closed and the drive bounds control so simultaneous conflicting control sources are prevented (one active control location); fieldbus connection limits. **Ext. tools:** Drive Composer session review; control-location config; Wireshark (fieldbus connections).	Sessions terminable; control source bounded; concurrency limited.	
SR/CR 2.7	Concurrent session control	Confirm concurrent sessions are bounded/limited and monitored. **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Concurrent session control verified individually.	
SR/CR 2.8	Auditable events	The drive has a **fault/event log** but no security-audit/syslog. Capture parameter-change attribution via a **Drive Composer backup compare**, the controlling PLC/SCADA, and a Modbus/EtherNet-IP-aware OT IDS on the cell; forward to the SIEM. **Ext. tools:** Drive Composer (backup/param compare); PLC/SCADA change log; OT IDS + SIEM.	Config changes attributable via backup-compare + PLC; drive/fieldbus events captured by IDS.	No native syslog - Compensating.
SR/CR 2.9	Audit storage capacity	Because security logging is off-device, confirm the PLC/SCADA/SIEM are sized/retained and alert on collection or drive comms-loss failure so events are not silently lost. **Ext. tools:** SCADA/SIEM retention + comms-loss alarm review.	Off-device logs sized/retained; audit-failure/comms-loss alerting defined.	Compensating.
SR/CR 2.10	Response to audit processing failures	Confirm a defined response to audit-processing/forwarding failures (alerting; no silent loss). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.9** above (shared steps); confirm this requirement individually and adjudicate it separately.	Response to audit processing failures verified individually.	
SR/CR 2.11	Timestamps	Confirm event correlation: the drive fault log timestamps relative to power-up or a panel RTC - sync the controlling PLC/SCADA (NTP) so drive events correlate. **Ext. tools:** Panel/Drive Composer (time source); PLC/SCADA NTP check.	Correlatable time via the synced PLC/SCADA (drive log referenced).	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	
EDR 2.13	Physical diagnostic & test interfaces	Control physical interfaces: locked cabinet; secure the removable **panel**, the **USB** port, the **RS-485 / fieldbus** terminals, and the **STO** terminals; use the user lock to disable USB/Bluetooth; shut/booted-off unused I/O. **Ext. tools:** Physical inspection (cabinet, panel, USB, STO terminals); confirm 96.102 disables USB/Bluetooth.	Physical/diagnostic interfaces controlled; USB/Bluetooth disabled via user lock.	EDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 3.1	Communication integrity	EFB Modbus RTU and the fieldbus (Modbus TCP / EtherNet-IP / PROFINET) are **unauthenticated cleartext**, and the FENA web is **HTTP** (no TLS on the drive) - integrity/confidentiality come from **containment**: keep drive comms in a segmented cell, disable the FENA web if unused, and let no cleartext control cross a zone boundary uncontrolled. **Test:** confirm fieldbus + FENA traffic stay in-zone; FENA web off if unused. **Ext. tools:** Wireshark (`modbus || enip` cleartext in-zone; FENA HTTP); `nmap -p 80,502,44818 .`	Drive comms contained/segmented; FENA web disabled if unused; no uncontrolled cleartext.	No crypto - Compensating.
SR/EDR 3.2	Protection from malicious code (component)	Confirm only ABB firmware runs; load firmware only via **Drive Composer** from ABB and verify provenance; the **user lock (96.102) can prevent firmware/file download** - keep it set except during controlled maintenance; patch Drive Composer (CISA ICSA-25-037-03). **Ext. tools:** Drive Composer (firmware version + provenance); confirm 96.102 blocks file/firmware load; ABB advisory review.	Only ABB firmware runs; download blocked via user lock; provenance verified; Drive Composer patched.	EDR-specific.
SR/CR 3.3	Security functionality verification	After any change re-verify: user lock active + 96.102 selections, control-location config, FENA web disabled + fieldbus scope, firmware, against the ABB cybersecurity-guide baseline; use a Drive Composer parameter backup compare. **Ext. tools:** Drive Composer (param compare vs baseline); `nmap -p 80,502,44818 .`	Security settings match the hardening baseline after change.	
SR/CR 3.4	Software & information integrity	Protect the **parameter set + adaptive program**: back up via Drive Composer (.dcparamsbak), hash it, host ACLs, version control; the user lock + parameter lock prevent unauthorized change; detect drift by backup compare. **Ext. tools:** Drive Composer backup; `certutil -hashfile .dcparamsbak SHA256`; param compare for drift.	Parameter/adaptive-program integrity protected; unauthorized change prevented/detected.	
SR/CR 3.5	Input validation	Confirm the drive tolerates malformed **Modbus / EtherNet-IP / PROFINET** frames without faulting or an unexpected trip/start. **ISOLATED bench only:** fuzz the fieldbus on a bench drive (motor uncoupled) and watch the drive fault log + output. **Ext. tools:** Fieldbus fuzzer (`boofuzz` Modbus/EtherNet-IP) on a bench drive; Wireshark; watch fault/trip + STO.	No fault/unexpected start on malformed input.	Do NOT fuzz an in-service drive.
SR/CR 3.6	Deterministic output	**Safety-critical row.** Verify the **STO (Safe Torque Off)** wiring/function removes torque independently of comms, and the configured **fault-stop mode** (coast / ramp) and the **fieldbus comm-loss fault action** drive a defined safe stop (not a runaway). If an **FSO-12/FSO-21** safety module is fitted, verify its safety function (PROFIsafe / CIP Safety). **Test:** ISOLATED: trigger STO / simulate fieldbus comm loss -> drive removes torque / performs the configured safe stop. **Ext. tools:** STO/FSO bench test; Drive Composer (comm-loss fault action / stop mode review).	STO removes torque independently of comms; comm-loss drives a defined safe stop.	Safety-critical.
SR/CR 3.7	Error handling	Confirm graceful fault handling: the drive faults/stops safely, the fault log records the cause, and any **automatic restart** config is reviewed (no unsafe auto-restart) with no info leak. **Ext. tools:** Drive Composer (fault log + auto-restart config review).	Graceful fault handling; no unsafe auto-restart or info leak.	
SR/CR 3.8	Session integrity	**N/A / limited.** No authenticated/encrypted fieldbus session (no TLS); integrity by containment. Record N/A + compensating segmentation. **Ext. tools:** Wireshark (confirm in-zone containment).	N/A/limited at device; compensating segmentation recorded.	N/A/Partial.
SR/CR 3.9	Protection of audit information	Since audit is off-device, protect the PLC/SCADA/IDS/SIEM store and restrict who can read/clear it; the drive fault log is read-only via the panel. **Ext. tools:** SCADA/SIEM access review.	Off-device audit records protected from unauthorized access.	
EDR 3.10	Support for updates	Update firmware via **Drive Composer** with firmware from ABB; verify version/provenance; keep the user lock's firmware-download prevention set except during a controlled maintenance window with a rollback plan. **Ext. tools:** Drive Composer (update flow + provenance); ABB firmware; rollback plan.	Controlled updates from a verified source, patched, with rollback; download otherwise blocked.	EDR-specific.
EDR 3.11	Physical tamper resistance/detection	Keep the drive in a locked/sealed cabinet; control the panel, USB, and fieldbus/STO terminals; the user lock deters config tamper; config drift is visible via Drive Composer compare. **Ext. tools:** Physical inspection (cabinet/seal, panel/USB); Drive Composer compare.	Cabinet secured; interfaces controlled; user lock set; drift detectable.	EDR-specific.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
EDR 3.12	Provisioning product-supplier roots of trust	**Partial.** ABB firmware is distributed by ABB and gated by the user lock, but there is no documented public secure-boot/signed-image attestation on ACS580. Record the level; compensate with firmware provenance (3.10), the user-lock download block, patching, and segmentation. **Ext. tools:** Confirm firmware provenance/signature level with ABB; user-lock download block.	Supplier trust via ABB provenance + user lock; attestation gap recorded.	EDR-specific/Partial.
EDR 3.13	Provisioning asset-owner roots of trust	**Partial/N-A at device.** No asset-owner certificate provisioning (no PKI on the drive). Record the gap; asset-owner trust is enforced at the network/PLC layer + physical + the user-lock pass code the owner controls. **Ext. tools:** Confirm no cert provisioning; segmentation + pass-code custody review.	No asset-owner RoT at device; user-lock + network controls compensate.	EDR-specific/Partial.
EDR 3.14	Integrity of the boot process	**Partial/N-A at device.** No published secure-boot attestation on ACS580. Record the gap; mitigate via firmware provenance (3.10), the user-lock download block, physical control, and monitoring. **Ext. tools:** Confirm boot-integrity level with ABB; firmware version review.	Boot-integrity gap recorded; compensating controls in place.	EDR-specific/Partial.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/repurpose, **restore factory defaults** (clear parameters + adaptive program), remove the panel, reset the FENA adapter, and destroy/secure parameter backups so site configuration is not recoverable. **Ext. tools:** Panel/Drive Composer (restore defaults); FENA reset; backup sanitize.	Parameters/adaptive program/adapter config purged on decommission or reuse.	
SR/CR 4.3	Use of cryptography	**N/A / limited.** No comms crypto on the drive; the user-lock pass code is stored hashed. Rely on segmentation; disable the FENA web. Where confidentiality across the fieldbus is required, add an external secure layer. **Ext. tools:** Confirm no comms crypto; FENA web off; Wireshark (no cleartext across boundary).	No comms crypto - compensating segmentation; pass code hashed; web off.	N/A/Partial.

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 5.1	Network segmentation	Confirm the drive sits in a segmented motor-control cell; only the intended PLC/master reaches the EFB RS-485 and the FENA fieldbus; the **FENA is the network exposure point** - firewall it (502/44818/2222/80) and disable its web if unused; no flat convergence with IT. **Ext. tools:** `nmap -p 502,44818,2222,80` per zone; firewall rule review.	Drive in a segmented cell; FENA firewalled; only required flows cross.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General-purpose person-to-person comms restrictions	**N/A.** Motor drive with no general-purpose person-to-person messaging. **Ext. tools:** Confirm no such services.	N/A - justification recorded.	N/A
SR 5.4	Application partitioning	Where an **FSO safety module** is used, keep the safety fieldbus (PROFIsafe / CIP Safety) logically separated from standard control; otherwise the drive is single-function. **Ext. tools:** Safety-bus vs standard-fieldbus separation review (if FSO fitted).	Safety and standard comms separated (FSO); else single-function (N/A).	FSO-specific.

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 6.1	Audit log accessibility	Confirm the drive **fault/event log** is readable/exportable via panel/Drive Composer/fieldbus and that a passive **Modbus/EtherNet-IP-aware OT IDS** on the cell + the PLC/SCADA capture drive events (trips, comm loss, param writes) and forward to the SIEM. **Ext. tools:** Drive Composer (fault-log export); PLC/SCADA; OT IDS + SIEM.	Drive events accessible/exportable and monitored off-device in near-real-time.	Compensating.
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 7.1	Denial-of-service protection	Confirm the drive is resilient: a fieldbus flood must not cause a runaway - verify the **fieldbus comm-loss fault action** drives a safe stop and that **STO** is independent of comms; firewall/rate-limit the FENA. **Ext. tools:** ISOLATED bench: fieldbus storm (`hping3 --flood -p 502`); confirm comm-loss safe stop + STO independence.	Comm loss drives a safe stop; STO comms-independent; FENA rate-limited.	Safety-relevant.
SR/CR 7.2	Resource management	Confirm bounded resources: the drive keeps controlling the motor under fieldbus load and one service cannot starve control; monitor. **Ext. tools:** Bench load test; drive diagnostics (fieldbus load).	Resources bounded; no comms-induced loss of motor control.	
SR/CR 7.3	Control system backup	Confirm the parameter set (Drive Composer .dcparamsbak) + adaptive program + FENA config are backed up (versioned, offline) and a restore is tested on a spare drive for a known-good rebuild. **Ext. tools:** Backup repository; `certutil -hashfile .dcparamsbak SHA256`; restore test (spare drive).	Backups current and recovery validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Harden per the ABB cybersecurity guide: enable the **user lock**, use **96.102** to disable USB / panel Bluetooth / firmware download when not maintaining, disable the FENA web + unused fieldbus protocols, set a non-default Modbus address, restrict control location, and patch firmware + Drive Composer. **Ext. tools:** Panel/Drive Composer (96.102 + address + control location); FENA web off; `nmap -p 80,502,44818 .`	Least functionality; user lock set; USB/BT/web disabled; non-default address; patched.	
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Inventory the drive type (ACS580/ACH580/ACQ580 + frame), firmware version, the fieldbus adapter (FENA/FEIP/FMBT/FPNO/FSCA) + its firmware, and any FSO safety module, so vulnerabilities track against ABB cybersecurity advisories / CISA (ICSA-25-037-03). **Ext. tools:** Panel/Drive Composer (type/firmware/adapter); ABB advisory feed.	Accurate drive/adapter/firmware inventory maintained; advisories tracked.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
Assistant control panel (ACS-AP-I/W/S)	Native user-lock & parameter review (most FRs)	Review/activate the user lock (group 96: 96.02 pass code, 96.100/96.101 change, 96.102 functionality), the control location, and the fault log; change the default pass code and record it securely.	Read-only; authorized; escrow the pass code.
Drive Composer Entry/Pro	Parameter/adaptive-program review, backup & firmware (1.x, 3.x, 7.x)	Review parameters + adaptive program; back up (.dcparamsbak) + compare for drift; manage firmware; read the fault log. Patch to the CISA-ICSA-25-037-03-fixed version.	Authorized; back up before changes.
FENA/FEIP adapter web UI	Fieldbus config & web exposure (1.3, 3.1, 5.x, 7.6)	Review the fieldbus adapter config; change default web credentials; DISABLE the web server when unused; confirm protocol/IP.	Authorized; read-only where possible.
modpoll / mbpoll	EFB/fieldbus read-back & write-scope (1.2, 2.1, 3.3)	`modpoll -m rtu -a -b -1 /dev/ttyUSB0` or `modpoll -m tcp -a` ; read status; confirm write scope (authorized/isolated).	Read-only on production; writes isolated.
nmap	FENA exposure & segmentation (1.13, 3.1, 5.x, 7.6)	`nmap -p 80,502,44818,2222` ; `nmap --script enip-info -p 44818` ; scan per zone; confirm web off/only required reachable.	Read-only; authorized.
Wireshark / tcpdump	Comms integrity & containment (3.1, 3.8)	Filter `modbus || enip`; confirm cleartext fieldbus + FENA HTTP stay in-zone.	Passive; SPAN/tap only.
Fieldbus fuzzer (isolated)	Input validation (3.5)	`boofuzz` Modbus/EtherNet-IP to a BENCH drive (motor uncoupled); watch fault log + STO/output.	ISOLATED bench; written authorization.
STO / FSO bench test	Deterministic/fail-safe output & DoS (3.6, 7.1)	Trigger STO / simulate fieldbus comm loss on a bench drive; confirm torque removal / configured safe stop independent of comms; verify FSO safety function if fitted.	ISOLATED bench; safety verification.
Passive OT IDS + ABB advisories	Monitoring & vuln tracking (2.8, 6.x, 7.8)	Modbus/EtherNet-IP-aware IDS on the cell for drive events/anomalous writes; track ABB cybersecurity + CISA advisories (ICSA-25-037-03).	Passive; coordinate with SOC.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.